AEGISCORE AI

Complete Project Blueprint, Research Strategy & Patent Exploration Plan

Evidence-driven • Business-impact-aware • Policy-constrained • Verified cybersecurity response

CORE IDEA | USPs 1–3 | ARCHITECTURE | TECHNOLOGY | COMPETITORS | RESEARCH | EXECUTION

Prepared 22 October 2026

Planning document; not a production security design or legal opinion

Executive summary

AegisCore AI is an organization-wide, context-aware cybersecurity operations and response-coordination platform. It ingests security telemetry, investigates suspicious activity across sources, understands relationships between assets and business services, recommends or executes policy-permitted changes, verifies the outcome, and produces an auditable report.

Build order: enterprise security workflow first. The developer/student copilot is a separate later module and is out of scope for the initial MVP.

Operating modes: Approval Mode is the default. AegisCore presents evidence, uncertainty, proposed action, affected services, alternatives and risks, then waits for an authenticated authorized approver. Automatic Mode is an explicit opt-in and can execute only actions preauthorized by policy; it verifies and reports after every action.

The strongest proposed differentiator is the combination of (1) business-impact-aware response planning, (2) evidence-gated, risk-adaptive autonomy, and (3) verified remediation and recovery. These are candidate research contributions, not confirmed unique features or patentable inventions.

Decision	Definition
Core product	Evidence-driven enterprise security operations and response coordination.
Primary users	SOC analysts, security engineers, IT/service owners, security leadership and auditors.
MVP	Synthetic telemetry, investigation, asset/dependency graph, policy engine, approval workflow, sandbox response, postcondition verification and audit.
Later	Real vendor integrations, production hardening, additional sources, separate coding copilot.
Research output	Repeatable benchmark comparing containment, unsafe actions, business disruption, evidence quality and verified recovery.
Patent strategy	Search prior art and define a specific technical mechanism; obtain registered patent-agent advice before disclosure or filing.

1. Core idea, problem and proposed solution

1.1 Problem

Security signals are fragmented across identity providers, endpoint tools, cloud audit logs, firewalls, SaaS applications and infrastructure. Analysts must correlate evidence, decide whether an alert is real, understand business context, coordinate approvals, execute response steps and confirm that the threat was contained without causing avoidable outages. Manual workflows can be slow; automation can be dangerous when evidence, permissions, scope or verification are weak.

1.2 Vision

AegisCore should answer five questions for every significant incident: What happened? What evidence supports that conclusion? What is the likely business impact? Which response is permitted and proportionate? Did the action actually achieve its objective?

1.3 Main workflow

1. Collect identity, endpoint, cloud, network and application events through source adapters.
2. Validate and normalize events into a common OCSF-aligned model; preserve raw source references.
3. Run deterministic rules and statistical detectors on the fast path; deduplicate and correlate events.
4. Investigate suspicious events through bounded agents that gather authorized evidence and record provenance.
5. Query the asset/dependency graph to identify affected identities, endpoints, services, databases, departments and owners.
6. Separate anomaly score, threat confidence, business impact, action risk and evidence sufficiency.
7. Generate candidate responses; reject those that violate policy, evidence requirements, scope or safety constraints.
8. Approval Mode requests authenticated authorization; Automatic Mode executes only explicit preauthorized actions.

9. Verify the actual resulting state using fresh observations; check security postconditions and service health.

10. Write the report, notify owners, preserve the audit record and feed confirmed outcomes into versioned evaluation.

1.4 Non-goals for MVP

- Replacing mature SIEM, EDR, XDR, IAM or SOAR products.
- Supporting every vendor and every event schema.
- Unrestricted production autonomy or self-granting permissions.
- Unreviewed self-modification of model weights, policies or deployment settings.
- Building the developer copilot before the core enterprise workflow works.
- Promising zero false positives, complete attack detection or guaranteed patentability.

2. Three priority USPs

USP 1 — Business-impact-aware threat response planning

Goal: select a permitted response that contains the threat while minimizing predicted disruption to legitimate business operations.

How it works

- Represent users, endpoints, identities, network zones, cloud resources, applications, databases, business services and owners as a dependency graph.
- Generate a bounded set of candidate actions, such as token revocation, targeted access restriction, credential disablement, endpoint quarantine or host isolation.
- Estimate security benefit, affected dependency set, blast radius, reversibility, service criticality and recovery effort for each action.
- Reject candidates that violate hard policy, required evidence or service constraints; rank remaining candidates and explain trade-offs.
- After execution, compare predicted impact with observed impact to improve calibration.

Example: A service identity appears compromised and can access a production database. Rather than immediately isolating a shared server, AegisCore compares a targeted token revocation, restriction of a specific path, and broader isolation. It explains the security benefit and likely operational consequences of each.

Research question: Does dependency-aware response planning reduce disruption to unaffected services while maintaining comparable containment?

Patent direction: a specific algorithm that combines a time-aware dependency graph, constrained candidate-action planning and post-action impact verification. Asset graphs and blast-radius analysis already exist; novelty is unconfirmed.

Metrics: unaffected services disrupted, estimated versus actual blast radius, containment success, response time and impact-estimate calibration.

USP 2 — Evidence-gated, risk-adaptive autonomy

Goal: prevent high-risk action merely because a model reports a high confidence score.

How it works

- Maintain separate anomaly, threat-confidence, business-impact, action-risk and evidence-sufficiency fields.
- Define evidence predicates per action class, target type and environment.
- When evidence is missing or contradictory, query additional authorized sources or escalate to a human.
- Enforce tenant, identity, scope, expiry, reversibility and policy checks independently of the LLM.
- Automatic Mode is limited to explicitly permitted actions that satisfy the policy’s evidence and scope requirements.

Example: A login from a new location is anomalous, but MFA succeeded and no suspicious token use is found. The system gathers more evidence or increases monitoring rather than automatically disabling a critical account.

Research question: Do action-specific evidence gates reduce unjustified remediation compared with fixed confidence thresholds?

Patent direction: an authorization mechanism jointly evaluating evidence sufficiency, action scope, reversibility and predicted impact. Approval gates and tiered autonomy already exist; the precise mechanism must be differentiated.

Metrics: unsafe-action rate, false-positive remediation, evidence coverage, human escalation rate and investigation latency.

USP 3 — Verified remediation and recovery loop

Goal: distinguish a command being issued from a security objective actually being achieved.

How it works

- Capture pre-action state and evidence references.
- Define machine-checkable preconditions and postconditions before execution.
- Execute through a restricted connector with idempotency, timeouts and action logging.
- Query the target system or fresh telemetry to verify actual state; do not trust an API success message alone.
- Check both security outcomes and service health.
- On failure or unknown outcome, stop repeated attempts and escalate or invoke a separately authorized recovery plan.
- Report what changed, what was verified, what remains uncertain and whether containment criteria were met.

Example: After revoking a suspected compromised token, AegisCore checks that the token is rejected, looks for continued suspicious activity and reports whether the objective was verified.

Research question: Does independent postcondition verification increase confirmed containment and expose failed remediation that command-status-only systems miss?

Patent direction: a closed-loop mechanism linking preconditions, scoped execution, independent postcondition checks and policy-controlled recovery. Generic remediation, health checks and rollback are established; the specific method needs prior-art analysis.

Metrics: verified-action success, discrepancy between command status and actual state, recovery success, time to verified containment and rollback frequency.

3. Architecture and data flow

Layer	Responsibility / recommendation
Sources	Synthetic identity, cloud audit, endpoint, firewall and application events first; add real read-only connectors later.
Ingestion	Vector or Python adapters; Kafka when replay, buffering and volume justify it; schema validation and dead-letter queue.
Normalization	OCSF-aligned Pydantic models, timestamps, tenant IDs, source IDs, parser version, deduplication and raw-event reference.
Fast detection	Rules, thresholds, feature extraction, statistical anomaly score, event windows and correlation.
Investigation	Sentry → Investigator → Validator; bounded queries, explicit evidence provenance, timeout and uncertainty handling.
Context	Neo4j dependency graph; PostgreSQL durable incidents/policies/audit metadata; Redis transient cache and coordination.
Decision	Separate threat confidence, evidence sufficiency, business impact, action risk and policy constraints.
Authorization	Default Approval Mode; optional Automatic Mode restricted to explicit preauthorized action classes.
Execution	Restricted connector, exact target/action scope, idempotency key, bounded retries, timeout and stop control.
Verification	Fresh state query, security postconditions, service-health checks, recovery branch and outcome report.
Observability	Latency, consumer lag, event loss/duplicates, connector errors, policy decisions, action outcomes and version IDs.

3.1 Agent responsibilities

Component	Allowed responsibility	Must not do
Sentry	Rules, features, anomaly flag, detector version and triggering fields.	Execute response or claim compromise from anomaly alone.
Investigator	Gather authorized evidence, correlate sources, record provenance and uncertainty.	Run arbitrary commands or invent missing evidence.
Validator	Check corroboration, contradictions, evidence sufficiency and action eligibility.	Override deny rules or grant permissions.
Planner	Compare candidate actions against security benefit, business impact and constraints.	Invent connector capabilities or bypass policy.
Executor	Execute authorized, scoped, idempotent actions.	Expand scope or retry indefinitely.
Verifier	Check fresh postconditions, service health and residual uncertainty.	Treat API success as proof of containment.

3.2 Suggested repository layout

```
aegiscore-ai/
apps/api/ # FastAPI routes and control plane
apps/dashboard/ # React + TypeScript
services/ingestion/ # adapters, parsers, normalization, dead letter
services/detection/ # rules, features, anomaly and correlation
services/investigation/ # Sentry, Investigator, Validator, evidence tools
services/context_graph/ # asset model and dependency queries
services/risk/ # confidence, impact, action risk, blast radius
services/policy/ # allowlists, authorization, policy versions
services/response/ # connectors, executor, verification, recovery
services/reporting/ # reports and notifications
services/audit/ # append-only decision records and integrity
services/evaluation/ # scenarios, baselines, metrics and runner
schemas/ # events, incidents, evidence, actions, policies
infrastructure/ # Docker Compose, migrations, observability
tests/ # unit, integration, security and scenario replay
docs/ # architecture, threat model, research
```

4. Technology stack

Area	Recommended technology	Reason / guardrail
Language/API	Python 3.12+, FastAPI, Pydantic	Backend, async APIs, typed schemas and ML integration.
Event transport	Vector; Kafka as needed	Collection, buffering, replay and decoupling. Start smaller if prototype volume is low.
Event schema	OCSF-aligned model	Common event vocabulary; preserve raw references and validate mappings.
Durable database	PostgreSQL	Incidents, policies, approvals, connector metadata, audit references and results.
Graph database	Neo4j	Asset and business dependency traversal.
Cache	Redis	Transient state, rate limiting and bounded deduplication; not sole history.
Evidence archive	S3-compatible store / MinIO in development	Raw events and evidence artefacts with retention and access control.
Orchestration	LangGraph or explicit state machine	Stateful bounded workflows, checkpoints and human interrupt; deterministic policy remains outside LLM.
Detection	Rules + scikit-learn	Transparent baseline such as Isolation Forest; validate against labelled scenarios.
LLM	Provider abstraction; hosted or local model	Use for synthesis/explanation, not as sole detector or authorization engine.
Frontend	React + TypeScript + Vite + Tailwind	Dashboard, evidence inspector, approval queue and action reports.
Graph/charts	Cytoscape.js or React Flow; Recharts/Plotly	Choose only the visualization tools the MVP needs.
Identity	OIDC provider + RBAC	Authenticated sessions, approver roles and least privilege.
Testing	pytest, contract/integration tests	Test normal, malicious, incomplete, duplicate and failure scenarios.
Deployment	Docker Compose first; Kubernetes later if justified	Repeatable local setup before production complexity.
Observability	OpenTelemetry + Prometheus/Grafana	Latency, lag, errors, action outcomes and trace IDs.
CI/CD	GitHub Actions or equivalent	Tests, linting, dependency checks and versioned releases.

4.1 Model strategy

- Start with deterministic rules and a small statistical baseline; measure before adding complexity.
- Use an LLM for evidence synthesis, explanation and candidate-action reasoning; validate structured output against schemas.
- Treat logs, retrieved documents and tool output as untrusted data, never as instructions.
- Version models, prompts, retrieval corpus, rules and policies separately; do not self-modify production behavior without evaluation and approval.
- Keep model provider behind an interface so identical scenarios can be tested across models.

5. Event model, state and scoring

5.1 Core event fields

Field	Purpose
event_id / tenant_id	Stable event identity and mandatory tenant boundary.
time_observed / time_ingested	Source timestamp and platform ingestion timestamp; preserve timezone and clock-skew handling.
source_product / source_event_id	Original product and source record reference.
event_class / activity / outcome	Normalized event type, action and result.
actor / target / device / network	Entities with source provenance and confidence.
raw_event_ref	Pointer to original payload in controlled evidence storage.
schema_version / parser_version	Reproducibility as mappings evolve.

5.2 Incident state

Persist incident_id, tenant_id, trigger event IDs, affected entity IDs, detector version, anomaly score, threat confidence, evidence sufficiency, evidence items, graph version, business-impact estimate, candidate actions, selected action, policy version, authorization state, approver identity, execution record, postcondition results, service-health result, final status, timestamps and report reference.

5.3 Score dimensions

Dimension	Meaning	Use
Anomaly score	How unusual an event or sequence is.	Prioritize investigation.
Threat confidence	How strongly evidence supports a malicious explanation.	Decide whether to gather evidence or escalate.
Business impact	Importance and dependency impact of affected services.	Prioritize and notify owners.
Action risk	Potential harm, scope, irreversibility and blast radius of a response.	Choose authorization level.
Evidence sufficiency	Whether action-specific required evidence is present and corroborated.	Gate action eligibility.

Do not collapse these into one score. Criticality should raise the need for careful handling, not turn weak evidence into strong evidence.

6. Policy and authorization

6.1 Approval Mode — default

- Show incident summary, source evidence, uncertainty, affected services, proposed action, impact estimate, alternatives, reversibility and verification plan.
- Require an authenticated user with the correct role to approve the exact action and scope.
- Bind approval to target, parameters, policy version and expiry; material changes require new approval.
- Re-check current preconditions and approval immediately before execution.
- Record approval/rejection, reason, policy version, execution and verification result.

6.2 Automatic Mode — opt-in

- Enable only through an authorized administrator and documented policy change.
- Allowlist each action type, target scope, prerequisites, blast-radius limit, rate limit and expiry.
- Never bypass evidence requirements or the independent policy engine.
- Start with sandbox and low-risk reversible actions; production changes remain approval-required by default.

• Verify after every action and stop/escalate on unknown state or failed postconditions.

Tier	Examples	Default control
0 — observe	Enrich alert, query logs, generate report.	Automatic under read-only scope and rate limits.
1 — low-impact reversible	Temporary watch, test token revocation, disposable lab endpoint quarantine.	Automatic only in sandbox or explicit preapproved scope.
2 — material	Disable employee account, quarantine production endpoint, change cloud security group.	Approval required in initial release.
3 — critical / broad	Production network policy, critical identity infrastructure, tenant-wide controls.	Strong designated approval; model cannot authorize itself.

Failure handling must include idempotency, bounded retries, timeouts, circuit breakers, action-state tracking, connector health checks, manual stop and unknown-outcome handling. Rollback is itself consequential and must be authorized and verified.

7. Competitors and differentiation

Public product descriptions show that AI investigation, multi-agent workflows, automation, approval gates, security context and auditability already exist in various forms. Vendor capabilities change by product tier and configuration; this is a market scan, not an independent product benchmark.

Product	Publicly described overlap	Implication
Microsoft Security Copilot	AI investigation, summaries, threat analysis, custom agents/workflows.	A security copilot alone is not a USP.
CrowdStrike Charlotte AI	Agentic SOC workflows, investigations, custom agents and response.	Need precise cross-vendor change governance and outcome verification.
Google Security Operations / Gemini	Triage, investigation, threat hunting, detection engineering and configured autonomy.	Approval/automatic mode is established.
Palo Alto Cortex XSIAM	Unified data, detection analytics, AI-assisted investigation and response.	Broad “AI SOC platform” positioning is crowded.
Torq AI SOC	AI agents, case management, workflow automation and assisted/autonomous response.	Generic orchestration is insufficient.
Radiant Security	AI-assisted triage, investigation and remediation workflows.	Demonstrate measurable benefit beyond faster investigation.
Dropzone AI	Autonomous alert investigation and reports.	Reports alone do not prove remediation.
Tines	Workflow automation with embedded AI agents and integrations.	Differentiate with specific security decision and verification mechanism.

7.1 Potential differentiators to test—not claim as untouched

- One action-selection model combining dependency graph, blast radius, reversibility, service criticality and hard security constraints.
- Action-specific evidence predicates enforced outside the LLM, with explicit uncertainty and escalation.
- Closed-loop verifier that uses fresh state observations to distinguish command acceptance from confirmed security outcome.
- One versioned record linking evidence, policy, approval, execution, postconditions and recovery.
- Reproducible benchmark measuring containment and business disruption together.

Correct claim language: “AegisCore proposes to investigate and evaluate…” until experiments and prior-art review justify stronger statements.

7.2 Vendor references

Microsoft Security Copilot

CrowdStrike Charlotte AI

Google Security Operations agentic SOC

Palo Alto Cortex XSIAM

Torq

Radiant Security

Dropzone AI

Tines

8. Patent exploration

The following are invention directions to investigate, not confirmed patentable inventions. Patentability depends on claims, priority dates, jurisdiction, novelty, inventive step, eligible subject matter and disclosure. A registered patent agent should review the full record.

Candidate A — Dependency-aware response selection

Possible title: System and Method for Selecting Security Remediation Actions Using Dependency-Constrained Impact Estimation.

Technical problem: broad containment actions can disrupt dependent services even when a narrower action may satisfy security constraints.

Mechanism to specify: versioned dependency subgraph; candidate-action generation; action-specific benefit and impact estimates; hard constraint filtering; ranking; execution; observed-impact comparison.

Technical effect to test: fewer unaffected services disrupted at comparable containment rates.

Prior-art risk: asset graphs, blast-radius analysis and risk-based remediation are established; a concrete algorithm is necessary.

Candidate B — Action-specific evidence sufficiency

Possible title: Action-Specific Evidence Sufficiency Evaluation for Policy-Constrained Cybersecurity Automation.

Mechanism: evidence predicates per action/target; source provenance, freshness and corroboration checks; contradiction handling; scope and reversibility checks; authorize, gather more evidence or escalate.

Technical effect to test: lower unsafe-action rate without excessive delay.

Prior-art risk: policy engines, confidence thresholds and human approval are established; broad claims are weak.

Candidate C — Independently verified remediation

Possible title: Closed-Loop Cybersecurity Remediation with Independently Observed Postcondition Verification.

Mechanism: preconditions and baseline state; scoped action; fresh state query; postcondition comparison; service-health check; success/partial/failure classification; authorized recovery branch; durable evidence record.

Technical effect to test: identify failed remediation that command-status-only workflows miss.

Prior-art risk: closed-loop control, health checks and rollback are established; exact implementation must be compared.

8.1 Preliminary prior-art leads

US20250202911A1 — generative AI cybersecurity remediation

US12093374B1 — AI-based incident response

US20250274471A1 — interactive AI response/restoration

US20260127274A1 — agent-based cyber incident management

Google Patents

WIPO PATENTSCOPE

Indian Patent Office patent guidelines

India CRI guidelines 2025 PDF

8.2 Patent workflow

1. Keep a dated invention notebook: problem, algorithm, diagrams, alternatives, experiments and team contributions.
2. Search patent families, full claims, priority dates, cited documents and non-patent literature by mechanism—not just project name.
3. Create a claim chart mapping each proposed technical step against the closest disclosures.
4. Measure a technical effect against a baseline where possible.
5. Clarify inventorship and ownership under university, team, sponsor and hackathon agreements.
6. Consult a registered patent agent before public disclosure or filing; plan jurisdiction and deadlines professionally.
7. Do not assume a provisional filing makes an incomplete idea protectable; plan the complete specification deadline with counsel.

Legal disclaimer: this document is not legal advice, a freedom-to-operate opinion or a patentability assessment. Public disclosure can affect rights; consult a professional before publishing or pitching potentially patentable details.

9. Research paper strategy

9.1 Recommended working title

Business-Impact-Aware, Evidence-Gated Cybersecurity Response with Closed-Loop Remediation Verification.

9.2 Hypothesis and research questions

Hypothesis: compared with fixed-playbook or fixed-threshold response baselines, dependency-aware action planning, action-specific evidence gates and post-action verification can reduce avoidable disruption and unsafe remediation while maintaining acceptable containment.

1. RQ1: Does dependency-aware planning reduce disruption to unaffected services?
2. RQ2: Do evidence gates reduce false-positive or unjustified remediation?
3. RQ3: Does independent verification improve confirmed containment?
4. RQ4: What trade-off exists between response latency, human escalation and safety?
5. RQ5: Which component contributes most in an ablation study?

9.3 Baselines

Condition	Description
Baseline A	Rule-based detection with fixed thresholds and conventional playbooks.
Baseline B	AI-assisted investigation/reporting with conventional response choices.
AegisCore full	Dependency planning + evidence gates + policy enforcement + postcondition verification.
Ablation 1	Remove dependency-aware impact planning.
Ablation 2	Remove evidence gates.
Ablation 3	Remove post-action verification.

9.4 Scenarios

- Suspicious login followed by token use from a second device.
- Compromised service identity accessing a sensitive database.
- Anomalous but benign login with corroborating MFA evidence.
- Cloud security-group change exposing a test service.
- Lateral movement attempt across a simulated department boundary.
- Duplicate/delayed telemetry that could trigger repeated action.

- Connector unavailable or action result ambiguous.
- Prompt-injection-like instructions embedded in untrusted log content.
- Critical service dependency where full isolation would disrupt business.
- API reports success but the target state remains unsafe.

9.5 Metrics

Metric	Definition
Precision/recall/F1	Classification against labelled ground truth; not a substitute for action safety.
Unsafe-action rate	Actions violating policy, lacking required evidence or exceeding scope.
Containment success	Scenarios where malicious activity stops and required postconditions confirm it.
Business disruption	Number/severity/duration of unaffected services disrupted.
Verified remediation	Actions with independently observed required postconditions.
Time to verified containment	Time from trigger event to verified security objective.
Evidence completeness	Decision claims traceable to source evidence.
Human escalation	Cases needing authorized human review, by severity and ambiguity.
Reliability	Event loss/duplicates, lag, connector failures and recovery behavior.

9.6 Paper outline

1. Abstract and keywords.
2. Introduction and motivation.
3. Related work: AI SOC agents, SOAR, risk-based response, dependency graphs, provenance and verification.
4. System model and threat model.
5. Method and algorithms.
6. Implementation and reproducibility.
7. Scenario dataset and ground-truth construction.
8. Experimental setup, baselines and ablations.
9. Results and statistical analysis.
10. Threats to validity, limitations and ethics.
11. Conclusion and future work.

10. Papers and essential reading

Study the following first. Recent preprints are useful but must be checked for publication status, venue and subsequent versions before formal citation.

10.1 Research papers

SecRespond: Benchmarking AI Agents for Real-World Post-Compromise Incident Response (2026)
Very relevant to forensic investigation, post-compromise workflows and verified remediation; study its scenarios and failure analysis.
https://arxiv.org/abs/2607.26791

Cyber Defense Benchmark: Agentic Threat Hunting Evaluation for LLMs in SecOps (2026)
Useful for evaluating threat hunting over raw telemetry rather than curated question answering.
https://arxiv.org/abs/2604.19533

ALERT: A Closed-Loop SOC Agent for Web and API Security with CVE-Based Intelligence and Adaptive Anomaly Detection (IEEE, 2026)
Important adjacent work on closed-loop response, human-in-the-loop policy and adaptive detection; compare mechanisms

carefully.
https://ieeexplore.ieee.org/document/11449910/

NIST AI Risk Management Framework
Governance, measurement and management of AI risk.
https://www.nist.gov/itl/ai-risk-management-framework

NIST Generative AI Profile
Risk-management guidance for generative AI systems.
https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

NIST SP 800-61 Rev. 3
Incident response and cybersecurity risk management.
https://csrc.nist.gov/pubs/sp/800/61/r3/final

10.2 Technical references and standards

OCSF

OCSF schema repository

MITRE ATT&CK

ATT&CK STIX data

Apache Kafka documentation

LangGraph documentation

Neo4j documentation

NIST CSF 2.0

10.3 Paper-reading template

- Record problem, threat model, assumptions and limitations.
- Record dataset, labels, baselines, metrics and reproducibility.
- Extract the exact mechanism that overlaps with AegisCore.
- Identify unanswered questions without claiming a gap before checking related work.
- Maintain a citation matrix: contribution, method, data, result, limitation, overlap and planned extension.

11. User experience and reporting

Screen	Core elements
SOC overview	Incidents, unresolved uncertainty, connector health, event lag, verified containment metrics.
Incident investigation	Timeline, evidence cards, entity relationships, confidence dimensions, contradictions and unknowns.
Asset/service graph	Users, endpoints, cloud assets, service ownership, dependencies, graph version and provenance.
Response proposal	Candidate actions, benefit, affected services, reversibility, evidence needs, risk and alternatives.
Approval queue	Authenticated approver, exact scope, policy version, expiry, approve/reject and reason.
Automatic-mode policies	Action allowlist, target scope, thresholds, rate limits, expiration and change history.
Verification	Preconditions, execution result, fresh postcondition evidence, service health, outcome and recovery state.
Audit/reporting	Decision timeline, evidence provenance, policy/model versions, export and notifications.

Example incident report

Executive summary: A service identity exhibited unusual access. Investigation correlated a login with token use from an unfamiliar endpoint. Evidence supports a suspicious identity-use hypothesis; compromise remains uncertain until specified checks complete.

Evidence: event IDs, source systems, timestamps, query references, corroborating/contradictory observations, freshness and data gaps.

Business impact: affected identity, accessible services, criticality, dependency path and confidence in estimated blast radius.

Proposed action: scoped response, expected effect, alternatives, risk and approval requirement.

Outcome: action result, independently observed postconditions, continued-activity check, service-health check, residual uncertainty and next step.

Never let the LLM invent event IDs, ATT&CK; IDs, CVEs, root causes or successful containment. Populate factual fields from validated records.

12. Security and privacy threat model

Threats

- Prompt injection embedded in logs, tickets, documents or threat intelligence.
- Overprivileged or compromised connectors.
- Cross-tenant leakage through APIs, graph queries, caches, retrieval or model context.
- Replay, spoofed events, clock skew, malformed payloads and duplicates.
- Unauthorized/stale approvals or action parameter mismatch.
- Hallucination, unsafe tool selection, unbounded loops and excessive tool use.
- Connector timeout with unknown action outcome.
- Audit-store tampering, exposed secrets and supply-chain vulnerabilities.

Controls

- Treat telemetry and retrieved content as untrusted data, never instructions.
- Use tool allowlists, schema validation, egress restrictions, bounded queries and timeouts.
- Use least-privilege credentials, short-lived tokens and secret management.
- Test tenant isolation across APIs, databases, cache and graph.
- Bind approvals to exact parameters, target, expiry and policy version.
- Re-check authorization immediately before execution.
- Use rate limits, idempotency, circuit breakers, safe stop and human override.
- Protect audit records with separately controlled administration and integrity checks.
- Run destructive tests only in an authorized sandbox.

Use NIST CSF 2.0, NIST SP 800-61 Rev. 3, and NIST AI RMF/Generative AI Profile as guidance references; implementing them does not automatically certify the product.

13. Execution roadmap

Target approximately 12–16 weeks for a focused prototype with consistent work. Real integrations, security assessment, reliability and enterprise deployment will take longer.

Phase	Timing	Deliverables / exit criteria
0. Research and scope	Week 1	Competitor/prior-art matrix, threat model, use cases, schemas and metrics.
1. Foundation	Weeks 2–3	Repo, Docker Compose, FastAPI, PostgreSQL, synthetic event generator, tests and dashboard shell.
2. Ingestion	Weeks 3–4	2–3 simulated sources, normalization, validation, deduplication, dead-letter and replay.
3. Detection	Weeks 4–5	Rules, simple anomaly baseline, incident lifecycle and labelled scenarios.
4. Investigation	Weeks 5–7	Agents, evidence references, bounded queries, uncertainty and structured report.
5. Graph/impact	Weeks 7–8	Asset dependencies, ownership, candidate actions and initial blast-radius estimates.

Phase	Timing	Deliverables / exit criteria
6. Approval mode	Weeks 8–9	Authentication, RBAC, exact-scope approval, policy versions and audit.
7. Automatic sandbox	Weeks 9–10	Preapproved low-risk lab actions, idempotency, timeout and stop controls.
8. Verification	Weeks 10–11	Fresh postcondition queries, service health, partial/failure results and recovery branch.
9. Evaluation	Weeks 11–13	Baselines, ablations, adversarial scenarios, metrics and repeatable reports.
10. Paper/demo	Weeks 14–16	Reproducible demo, architecture docs, research draft and patent consultation package.

MVP definition of done

- A suspicious scenario can be replayed from raw event to final report.
- Every factual claim links to evidence or is labelled inference.
- Threat confidence and action risk are separate and visible.
- Dependencies influence response recommendations.
- Approval requires an authenticated authorized user and binds to exact action parameters.
- Automatic Mode only executes explicitly permitted sandbox actions.
- Fresh observations verify the resulting state.
- Unknown outcomes do not trigger uncontrolled retries.
- Decision/action/outcome records are durable and searchable.
- Tests measure safety, containment, disruption, latency and evidence completeness.

Suggested team ownership

Role	Ownership
Backend/platform	FastAPI, schemas, ingestion, durable stores and integration contracts.
Detection/research	Scenario design, rules, baseline models, metrics and paper experiments.
Graph/risk	Asset model, dependencies, blast radius and candidate ranking.
Agent/policy	Investigation workflow, evidence gates, authorization and action state.
Frontend	Dashboard, evidence inspector, approval queue and action reports.
QA/security/docs	Threat model, adversarial tests, audit tests, reproducibility and prior-art matrix.

14. Evaluation and acceptance criteria

Set thresholds before final experiments. The following are provisional engineering targets, not achieved results.

Area	Provisional target	Validation
Evidence provenance	100% of factual report claims trace to a source record or are labelled inference.	Automated schema and reference checks.
Authorization	Zero out-of-scope actions in the test suite.	Wrong tenant, stale approval, altered parameters and deny-policy tests.
Post-action verification	Every executed action has success/partial/failure/unknown result.	Connector contract and fault-injection tests.
Idempotency	Duplicate delivery does not cause duplicate high-impact action.	Replay duplicates and retry responses.
Fail-safe behavior	Unknown state blocks further high-impact action and escalates.	Timeout and partial-failure tests.
Detection quality	Set target after baseline; report precision/recall and uncertainty.	Labelled scenarios and held-out cases.
Business impact	Compare predicted versus observed dependency effects.	Known dependency graph ground truth.

Area	Provisional target	Validation
Reproducibility	Results trace to scenario/config/model/policy version.	Versioned scenario runner.

Research discipline

- Use held-out scenarios and repeat stochastic runs where relevant.
- Report sample sizes and uncertainty; do not generalize from hand-picked demos.
- Compare against more than one baseline where feasible.
- Use ablations to isolate each USP's contribution.
- Report negative and mixed results; synthetic data has limitations.

15. Risks, budget and future roadmap

Risk	Mitigation
Scope explosion	Build a narrow enterprise vertical slice; defer copilot and broad integrations.
False positives	Evidence gates, human approval, staged automation and measured unsafe-action rate.
LLM hallucination	Structured outputs grounded in validated evidence and provenance checks.
Unclear novelty	Claim only a tested contribution; conduct claim-by-claim prior-art review.
Weak research	Ground truth, baselines, ablations and reproducible evaluation.
Integration complexity	Adapter contracts; synthetic data first; expand incrementally.
Incomplete dependency graph	Expose graph completeness/confidence and use conservative estimates.
Automation harm	Preauthorized narrow actions, policy outside LLM, stop switch and verification.
Sensitive telemetry	Data minimization, redaction, retention controls, least privilege and tenant isolation.

Budget approach

Use synthetic data and Docker Compose locally first; incremental cost may be near zero if existing hardware is sufficient, excluding electricity and optional model API use. Cloud costs depend on region, volume, retention, model provider and licensing. Obtain current quotes before planning a real pilot. Production requires high availability, backups, IAM, monitoring, security assessment, incident support and operational ownership.

Future copilot module

Add only after the enterprise workflow is reliable. Keep its permissions, storage, tools and execution sandbox separate from enterprise security data and response credentials. Possible capabilities: repository-aware debugging, security checks, patch proposals and sandboxed tests, with human review before repository modification or deployment.

Post-MVP enterprise roadmap

- Add real read-only connectors after synthetic scenarios pass.
- Add ticketing, network, SaaS and asset inventory integrations incrementally.
- Add policy simulation, dry-run previews, connector health and service-owner workflows.
- Add multi-tenant isolation, high availability and formal security testing before production use.

16. Final project definition

AegisCore AI is an evidence-driven, context-aware cybersecurity operations platform that investigates suspicious activity across enterprise systems, models business dependencies, and recommends or executes policy-permitted responses. Its central research direction combines business-impact-aware response planning, action-specific evidence gates, and closed-loop remediation verification. Approval Mode is the default; Automatic Mode is restricted to explicitly preauthorized actions and records and verifies outcomes.

Judge the platform by whether it safely contains defined threats, reduces avoidable disruption, produces traceable explanations and verifies real system state—not by number of agents, model size or dashboard features.

The strongest research path is a reproducible comparison of these three mechanisms. The strongest patent path is a narrowly specified technical mechanism with demonstrated technical effect and professional prior-art review. Neither novelty nor patentability is guaranteed.

Appendix — Reference links

OCSF

OCSF schema repository

MITRE ATT&CK

MITRE ATT&CK STIX data

Apache Kafka

LangGraph

Neo4j

NIST CSF 2.0

NIST SP 800-61 Rev. 3

NIST AI RMF

NIST GenAI Profile

SecRespond

Cyber Defense Benchmark

ALERT IEEE publication

Indian Patent Office guidelines

Google Patents

WIPO PATENTSCOPE

Glossary

Term	Meaning
OCSF	Open Cybersecurity Schema Framework.
SOAR	Security Orchestration, Automation and Response.
EDR/XDR	Endpoint Detection and Response / Extended Detection and Response.
Blast radius	Entities/services potentially affected by an incident or action.
Evidence provenance	Traceable source, collection time and transformation history.
Postcondition	Testable condition expected after an action.
Idempotency	Repeated request does not create unintended duplicate effect.
Ablation	Experiment removing one component to measure its contribution.
Prior art	Earlier disclosures relevant to patent assessment.
Freedom to operate	Legal analysis of potential infringement of enforceable patent rights.